



بنك الأفاق

AL-AFAQ BANK

Global Horizon Banking | صلاية استثمارية .. وأفاق عالمية |

إدارة المراجعة والتدقيق الداخلي — نظام إدارة أمن المعلومات (ISMS)

تقرير التدقيق الداخلي

Internal Audit Report

مجالات نظام إدارة أمن المعلومات المشمولة:
البند 4 (سياق المنظمة)، 5 (القيادة)، و 6 (التخطيط)

تصنيف الوثيقة)	سري — للاستخدام الداخلي فقط
مرجع الوثيقة	ISMS-DOC-09-5
الإصدار	1.0
تاريخ التقرير	13 سبتمبر 2026
مُعد التقرير	أ. أحمد الغامدي (مدير إدارة التدقيق والمراجعة الداخلية - Lead Auditor)
مالك الوثيقة	د. نورة القحطاني (الرئيس التنفيذي) / لجنة التدقيق والمخاطر بمجلس الإدارة

سجل المراجعات (Revision History)

الإصدار	التاريخ	معد المراجعة	ملخص التعديلات
1.0	13 سبتمبر 2026	أ. أحمد الغامدي	الإصدار المعتمد الأول لتقرير التدقيق الداخلي لنظام إدارة أمن المعلومات (المرحلة الأولى: البنود 4، 5، 6) لبنك الأفاق الرقمية وفق ISO/IEC 27001:2022 وإطار SAMA CSF.
0.2	09 سبتمبر 2026	فريق التدقيق الداخلي	مسودة الملاحظات الأولية وجلسة الإغلاق مع مالكي العمليات ومسؤولي أمن المعلومات.

قائمة التوزيع (Distribution)

الاسم / الجهة (NAME)	المسمى الوظيفي / الدور (TITLE)
د. نورة القحطاني	الرئيس التنفيذي (Chief Executive Officer)
أ. عبدالله المحيسن	رئيس مجلس الإدارة ورئيس لجنة التدقيق والمخاطر
أ. سارة الحربي	مدير أمن المعلومات (- Chief Information Security Officer (CISO
م. خالد السالم	مدير إدارة تقنية المعلومات (Chief Technology Officer / IT (Director
أ. فهد العتيبي	مدير إدارة العمليات المصرفية والأنظمة الأساسية

الاعتماد والتوقيع (Approval)

الاسم	المنصب	التوقيع	التاريخ
أ. أحمد الغامدي	مدير التدقيق الداخلي (Lead (Auditor	معتد إلكترونياً	13 سبتمبر 2026
أ. عبدالله المحيسن	رئيس لجنة التدقيق والمخاطر بمجلس الإدارة	معتد إلكترونياً	13 سبتمبر 2026
د. نورة القحطاني	الرئيس التنفيذي (CEO)	معتد إلكترونياً	13 سبتمبر 2026

المحتويات (Contents)

الإدارة

2 تفاصيل

التدقيق.

- 2.1 معايير التدقيق والوثائق المرجعية.
- 2.2 أهداف التدقيق.
- 2.3 نطاق التدقيق.
- 2.4 حالة حالات عدم المطابقة المسجلة في التقييم السابق.

3 نتائج

التدقيق.

- 3.1 سياق المنظمة.
- 3.2 القيادة.
- 3.3 التخطيط
- 3.4 حالات عدم المطابقة والملاحظات المسجلة.

4 خطة

الزيارة القادمة. 15

- 4.1 اليوم الأول.
- 4.2 اليوم الثاني.

الجداول

الجدول 1: نطاق التدقيق.

- الجدول 2: حالة حالات عدم المطابقة السابقة.
- الجدول 3: خطة الزيارة القادمة - اليوم الأول.
- الجدول 4: خطة الزيارة القادمة - اليوم الثاني.

1 ملخص الإدارة (Management Summary)

شملت أعمال هذا التدقيق الداخلي التقييم المنهجي والمستقل لمدى امتثال وفاعلية تطبيق بنود نظام إدارة أمن المعلومات (ISMS) التابع لبنك الأفاق الرقمية (Digital Horizons Bank)، وتحديد الأقسام الإلزامية الخاصة بسياق المنظمة (البند 4)، القيادة والالتزام (البند 5)، والتخطيط وإدارة المخاطر (البند 6) وفق متطلبات المعيار الدولي ISO/IEC 27001:2022 ومتطلبات إطار الأمن السيبراني للبنك المركزي السعودي (SAMA CSF).

بشكل عام، أظهرت نتائج التدقيق الميداني والمكتبي وجود مستوى متميز من الدعم والالتزام المؤسسي من قبل الإدارة العليا ومجلس الإدارة بنجاح وتشغيل نظام إدارة أمن المعلومات، وتم تخصيص موارد مالية وبشرية كافية (من خلال اعتماد ميزانية أمن المعلومات البالغة 18 مليون ريال سعودي). كما تبين أن البنك يمتلك فهماً شاملاً ودقيقاً لقضاياها الداخلية والخارجية وتطلعات الجهات المعنية.

تم إجراء تقييمات شاملة لمخاطر أمن المعلومات استناداً إلى منهجية موثقة ومعتمدة (ISMS-RT-01)، ووضعت خطة معالجة متينة لمعالجة المخاطر التي تتجاوز حدود القبول المعتمدة. ومع ذلك، لاحظ فريق التدقيق أن معايير قبول ومراقبة بعض المخاطر التراثية بحاجة إلى مزيد من الدقة والتحديث المستمر.

أما النتيجة الرئيسية الأبرز للتدقيق، فتتمثل في ضرورة صياغة واعتماد مؤشرات أداء تفصيلية (KPIs) وأهداف أمنية كمية وقابلة للقياس على مختلف المستويات التشغيلية والإدارية في البنك، لضمان تقييم فاعلية ونجاح النظام بصورة دورية وموضوعية. ويجب معالجة هذه الفجوة على وجه السرعة كأولوية قصوى قبل موعد التدقيق الخارجي لمنح الشهادة الدولية.

2 تفاصيل التدقيق (Audit Details)

تواريخ التدقيق (DATE/S)	من 06 سبتمبر 2026 إلى 08 سبتمبر 2026
مواقع التدقيق (LOCATION/S)	المقر الرئيسي (الرياض)، مركز البيانات الأساسي (الرياض)، مركز التعافي الكوارث (جدة)، وإدارة القنوات الرقمية
فريق التدقيق (AUDITOR/S)	أ. أحمد الغامدي (مدقق رئيسي)، أ. مريم السديري (مدقق نظم معلومات أول)، م. عمر الصالح (مدقق أمن سيبراني)
المشاركون من البنك (AUDIT PARTICIPANTS)	أ. سارة الحربي (CISO)، م. خالد السالم (CTO)، أ. فهد العتيبي (العمليات المصرفية)، أ. منى الشريف (HR)، محمد عبدالغني العامري (فريق ISMS)
ملخص النطاق (SCOPE SUMMARY)	فحص وتقييم تطبيق بنود المواصفة ISO/IEC 27001:2022: البنود 4 (السياق)، 5 (القيادة)، 6 (التخطيط)، وبيان انطباق الضوابط (SoA v1.0)

2.1 معايير التدقيق والوثائق المرجعية (Audit Criteria and Reference Documents)

استُخدم معيار ISO/IEC 27001، المعيار الدولي لأمن المعلومات، كأساس لمعايير التدقيق. كما استُخدمت مدونة الممارسات ISO/IEC 27002 عند الحاجة إلى توضيح متطلبات المعيار. وقد أُجري التدقيق باللغة العربية.

2.2 أهداف التدقيق (Audit Objectives)

تماشياً مع متطلبات المعيار، تتمثل الأهداف العامة لهذا التدقيق الداخلي في توفير معلومات حول ما إذا كان نظام إدارة أمن المعلومات (ISMS) الخاص بـ متجر شهاب (Shehab Store)

- يتطابق مع:
 - متطلبات متجر شهاب الخاصة بنظام إدارة أمن المعلومات لديه؛ و
 - متطلبات المعيار الدولي ISO/IEC 27001.
- مطبّق ويتم الحفاظ عليه بفعالية.

2.3 نطاق التدقيق (Scope of Audit)

يوضح الجدول 1 أدناه بنود وأقسام معيار ISO/IEC 27001:2022 التي شملها هذا التدقيق الداخلي بالتفصيل:

قسم وبند المواصفة (SECTION)	مشمول في التدقيق (INCLUDED)
4. سياق المنظمة (Context of the Organisation)	نعم (Y)
4.1 فهم المنظمة وسياقها الداخلي والخارجي	نعم (Y)
4.2 فهم احتياجات وتوقعات الأطراف المعنية	نعم (Y)

4.3 تحديد نطاق نظام إدارة أمن المعلومات	نعم (Y)
4.4 نظام إدارة أمن المعلومات والعمليات	نعم (Y)
5. القيادة والالتزام (Leadership)	نعم (Y)
5.1 القيادة والالتزام المؤسسي	نعم (Y)
5.2 سياسة أمن المعلومات المعتمدة	نعم (Y)
5.3 الأدوار والمسؤوليات والصلاحيات التنظيمية	نعم (Y)
6. التخطيط (Planning)	نعم (Y)
6.1 إجراءات التعامل مع المخاطر والفرص	نعم (Y)
6.2 أهداف أمن المعلومات والتخطيط لتحقيقها	نعم (Y)
6.3 التخطيط للتغييرات وإدارتها	نعم (Y)
7. الدعم والمساندة (Support) - الموارد، الكفاءة، التوعية، المعلومات الموثقة	مجدول للمرحلة الثانية
8. العمليات والتشغيل (Operation) - التخطيط التشغيلي وتقييم ومعالجة المخاطر	مجدول للمرحلة الثانية
9. تقييم الأداء (Performance Evaluation) - المراقبة والقياس ومراجعة الإدارة	مجدول للمرحلة الثانية
10. التحسين المستمر (Improvement) - حالات عدم المطابقة والإجراءات التصحيحية	مجدول للمرحلة الثانية
الملحق أ: الضوابط التنظيمية (A.5 Organizational controls)	مجدول للمرحلة الثانية
الملحق أ: ضوابط الأفراد والكوادر (A.6 People controls)	مجدول للمرحلة الثانية
الملحق أ: الضوابط المادية والبيئية (A.7 Physical controls)	مجدول للمرحلة الثانية
الملحق أ: الضوابط التقنية والتكنولوجية (A.8 Technological controls)	مجدول للمرحلة الثانية

مرجع: الجدول 1: نطاق تغطية بنود معيار ISO/IEC 27001 في التدقيق (Table 1: Scope of audit)

2.4 حالة حالات عدم المطابقة السابقة (Status of Nonconformities Raised at Last Assessment)

حتى تاريخ تنفيذ هذا التدقيق، تم التحقق من حالة حالات عدم المطابقة والملاحظات التي سُجلت خلال التقييم الأولي وفحص الفجوات السابق، وجاءت النتائج كما يوضح الجدول 2 أدناه:

الرقم (REF)	الوصف وتفاصيل الحالة (DESCRIPTION)	النوع (TYPE)	الإجراءات التصحيحية المتخذة (ACTIONS)	الحالة (STATUS)
NCR123	عدم مناقشة كفاية الموارد وميزانيات أمن المعلومات بتفصيل في اجتماعات مراجعة الإدارة السابقة.	عدم مطابقة صغرى	تم تحديث جدول أعمال أعمال مراجعة الإدارة، وتظهر محاضر الاجتماع الأخير مناقشة واعتماد ميزانية الـ 18 مليون ريال وتخصيص الموارد البشرية.	مغلقة (Closed)
NCR124	عدم التعامل مع أحد الحوادث الأمنية السابقة وفق التسلسل الإجرائي الموثق في وثيقة الاستجابة.	عدم مطابقة صغرى	تم إعداد ونشر إجراءات الاستجابة لحوادث أمن المعلومات (-ISMS DOC-A05-26-1) وتدريب فريق الاستجابة ومناوبي مركز SOC.	مغلقة (Closed)
OBS125	تفاوت في توثيق أصول تكنولوجيا المعلومات ومحطات العمل الموزعة بين الفروع.	ملاحظة تحسينية	تم اكتمال الربط الآلي لأجهزة اللابتوب البالغ عددها 2,000 جهاز مع نظام الإدارة المركزية Microsoft Intune وتحديث السجل.	مغلقة (Closed)

مرجع: الجدول 2: حالة حالات عدم المطابقة للتقييم السابق (Table 2: Status of previous nonconformities)

3 نتائج وملاحظات التدقيق (Audit Findings)

يوثق هذا القسم الملاحظات والنتائج التفصيلية التي أسفرت عنها عمليات الفحص والتدقيق في المجالات والبنود الثلاثة المشمولة:

3.1 سياق المنظمة (Context of the Organisation - البند 4)

أظهرت نتائج التدقيق فهماً متقدماً وشاملاً من قبل البنك لكافة القضايا الداخلية والخارجية المؤثرة على أمن المعلومات؛ حيث تمت مراعاة متطلبات وتوقعات الأطراف المعنية (المودعين، البنك المركزي SAMA، الموردين، والجهات القضائية) بدقة عالية. وقد تم توثيق نطاق نظام إدارة أمن المعلومات المعتمد لأغراض منح الشهادة ليكون:

«نطاق نظام ISMS المعتمد لدى بنك الأفاق الرقمية: «إدارة أمن المعلومات في تقديم وتطوير كافة المنتجات والخدمات المصرفية الرقمية، والأنظمة المصرفية الأساسية (Core Banking)، وبوابات الدفع الوطنية والدولية، والبنية التحتية لمراكز البيانات والعمليات التقنية المقدمة لعملاء بنك الأفاق الرقمية وشركائه وفق بيان الانطباق (Statement of Applicability) v1.0».

وقد تحقق فريق التدقيق من ملاءمة وصلاحيه هذا النطاق ومطابقته للواقع التشغيلي الفعلي للبنك.

3.2 القيادة والالتزام (Leadership - البند 5)

أثبتت الأدلة المقدمة التزاماً استثنائياً من الإدارة العليا؛ حيث ترتبط إدارة أمن المعلومات (CISO) مباشرة بالرئيس التنفيذي، وتم تخصيص ميزانية استثمارية كافية لتحديث البنية الأمنية. والسياسة العامة لأمن المعلومات (ISMS-DOC-05-4) معتمدة ومنشورة لكافة المنسوبين. ومع ذلك، لوحظ أن إيصال

الرسائل الأمنية التوعوية في الاجتماعات الدورية لفرق الفروع بحاجة إلى تعزيز مستمر (تم تسجيل الملاحظة OBS163). كما تم رصد عدم اكتمال تعميم إطار الأهداف الأمنية على بعض المستويات (تم تسجيل حالة عدم المطابقة الكبرى NCR142).

3.3 التخطيط وإدارة المخاطر (Planning - البند 6)

تم التحقق من إجراء تقييم المخاطر وفق منهجية معتمدة ومحكمة (ISMS-RT-01) مع إعداد تقرير تقييم المخاطر (ISMS-DOC-06-3)، وتعيين مالكين محددين لكل خطر ومتابعة خطط المعالجة. كما تم اعتماد بيان الانطباق (SoA v1.0). ومع ذلك، تبين أن معايير قبول بعض المخاطر التراثية واستثناءاتها (مثل نظام الرواتب القديم سيبيرولا) بحاجة إلى مزيد من الإحكام والتوثيق المعتمد (تم تسجيل حالة عدم المطابقة الصغرى NCR143).

3.4 حالات عدم المطابقة والملاحظات المسجلة (Nonconformities and Observations Raised)

عند رصد أي حيود أو فجوة عن متطلبات المواصفة القياسية، يتم تصنيف البند وفق الفئات المعتمدة الثلاث:

- عدم مطابقة كبرى: عدم مطابقة كبرى (Major Nonconformity): خلل جوهري أو قصور منهجي يمثل انهياراً في أحد متطلبات نظام الإدارة أو يهدد سلامة البيانات المصرفية.
 - عدم مطابقة صغرى: عدم مطابقة صغرى (Minor Nonconformity): زلة أو فجوة إجرائية فردية معزولة لا تشير بذاتها إلى انهيار في كفاءة نظام إدارة أمن المعلومات ككل.
 - ملاحظة تحسينية: ملاحظة وفرصة تحسين (Observation): ملحوظة مهنية استشارية تستهدف تحسين الممارسات ورفع كفاءة التطبيق.
- أسفر التدقيق عن تسجيل حالاتي عدم مطابقة (واحدة كبرى وواحدة صغرى) وملاحظة تحسينية واحدة وفق التفصيل التالي:

المرجع والرمز (REF)	NCR142
نوع النتيجة (TYPE)	عدم مطابقة كبرى (Major Nonconformity)
المجال والبند (AREA & CLAUSE)	البند 5.2 (السياسة) والبند 6.2 (أهداف أمن المعلومات والتخطيط لتحقيقها)
توصيف عدم المطابقة (DESCRIPTION)	سياسة أمن المعلومات وأدلة التشغيل لا تتضمن إطاراً مفصلاً لكيفية صياغة ومتابعة أهداف أمن المعلومات، ولم يتم تعميم مؤشرات أداء تفصيلية (KPIs) قابلة للقياس الكمي على كافة الوظائف والمستويات التشغيلية للبنك.
المتطلب المعياري (REQUIREMENTS)	يجب على الإدارة العليا وضع سياسة أمن المعلومات تتضمن أهدافاً واضحة أو توفر إطاراً لوضعها، كما يجب على المنظمة وضع أهداف لأمن المعلومات عند الوظائف والمستويات ذات الصلة وتكون قابلة للقياس ومراقبة النتائج.
الدليل والشواهد الميدانية (EVIDENCE)	بمراجعة السياسات المعتمدة ولقاءات مسؤولي الإدارات، لم يتم العثور على أهداف أمنية رقمية محددة لفريق قنوات الصيرفة الرقمية أو إدارة العمليات، واقتصرت الأهداف على عبارات عامة غير خاضعة لمؤشرات قياس كمية.

المرجع والرمز (REF)	NCR143
نوع النتيجة (TYPE)	عدم مطابقة صغرى (Minor Nonconformity)
المجال والبند (AREA & CLAUSE)	البند 6.1.2 (تقييم مخاطر أمن المعلومات ومعايير القبول)
توصيف عدم المطابقة (DESCRIPTION)	معايير وشروط قبول المخاطر الاستثنائية المؤقتة بحاجة إلى توثيق خطي أكثر دقة وإلزامية، وتحديد آلية المراجعة المستمرة للاستثناءات التقنية للأنظمة التراثية.
المتطلب المعياري (REQUIREMENTS)	يجب على المنظمة تحديد وتطبيق عملية لتقييم مخاطر أمن المعلومات تنشئ وتحافظ على معايير مخاطر أمن المعلومات التي تشمل معايير قبول المخاطر ومعايير إجراء التقييمات.
الدليل والشواهد الميدانية (EVIDENCE)	تبين من فحص سجل المخاطر وجود قبول مؤقت لمخاطر تطبيق سيبرولا التراثي دون وجود نموذج استثناء أمني رسمي موقع ومحدد بمدة انتهاء آلية مرتبطة بالربع الثالث 2026.

OBS163	المرجع والرمز (REF)
ملاحظة تحسينية (Observation)	نوع النتيجة (TYPE)
البند 5.1 (القيادة والالتزام المؤسسي)	المجال والبند (AREA & CLAUSE)
يمكن للإدارة التنفيذية الاستفادة بشكل أكبر من الاجتماعات الدورية للفروع ومراكز خدمة العملاء للتأكيد المباشر على أهمية الالتزام بسياسات أمن المعلومات.	توصيف الملاحظة (DESCRIPTION)
يجب على الإدارة العليا إثبات قيادتها والتزامها تجاه نظام إدارة أمن المعلومات من خلال تعزيز إيصال أهمية الإدارة الفعالة لأمن المعلومات والتوافق مع متطلبات النظام.	المتطلب المعياري (REQUIREMENTS)
أظهرت سجلات اجتماعات قطاع الفروع في الأشهر الستة الماضية عدم مشاركة ممثلي القيادة العليا في ورش التوعية الأمنية المباشرة مع موظفي الخطوط الأمامية.	الدليل والشواهد الميدانية (EVIDENCE)

4 خطة زيارة التدقيق القادمة (Next Visit Plan)

تقرر تنفيذ جولة التدقيق الداخلي التالية (المرحلة الثانية) على مدار يومين عمل كاملين تبدأ في 25 أكتوبر 2026 لتغطية باقي بنود المواصفة (البند 7، 8، 9، 10) وضوابط الملحق A الرقابية والتقنية. وقد تم إقرار الجدول الزمني المقترح وفق ما يوضحه الجدولان 3 و 4 أدناه:

4.1 جدول اليوم الأول (Day One Schedule)

الوقت (TIME)	المدقق (AUDITOR)	الجهة الخاضعة للتدقيق (AUDITEE)	المجالات والبنود المشمولة (AREAS TO BE COVERED)
09:00	أ. أحمد الغامدي	الإدارة التنفيذية و CISO	اجتماع الافتتاح واستعراض إغلاق حالات عدم المطابقة NCR142 و NCR143
10:00	أ. مريم السديري	الموارد البشرية والتدريب	البند 7 (الدعم: 7.1 الموارد، 7.2 الكفاءة، و 7.3 التوعية والتدريب الأمني)
11:00	م. عمر الصالح	مكتب إدارة الوثائق و IT	البند 7.5 (المعلومات الموثقة) وضوابط حماية السجلات وإجراءات التحكم
12:00	أ. أحمد الغامدي	إدارة العمليات المصرفية	البند 8 (التشغيل: 8.1 التخطيط والتحكم التشغيلي، 8.2 و 8.3 تقييم ومعالجة المخاطر)
13:00	فريق التدقيق	—	استراحة الغداء والصلاة
14:00	أ. مريم السديري	إدارة المشتريات والموردين	ضوابط الملحق A.5 (الضوابط التنظيمية: أمن سلاسل التوريد والخدمات السحابية - A.5.19 - A.5.23)
15:00	م. عمر الصالح	الموارد البشرية والأمن الإداري	ضوابط الملحق A.6 (ضوابط الأفراد: التدقيق قبل التوظيف وشروط التعاقد وإنهاء الخدمة)
16:00	أ. أحمد الغامدي	فريق ISMS وإدارة المخاطر	مراجعة فاعلية الضوابط التشغيلية وسجلات التدقيق الدوري
17:00	أ. أحمد الغامدي	CISO وفريق أمن المعلومات	جلسة تلخيص أعمال اليوم الأول ومراجعة الأدلة المستلمة

مرجع: الجدول 3: خطة التدقيق لليوم الأول (Table 3: Next visit plan - day one)

4.2 جدول اليوم الثاني (Day Two Schedule)

الوقت (TIME)	المدقق (AUDITOR)	الجهة الخاضعة للتدقيق (AUDITEE)	المجالات والبنود المشمولة (AREAS TO BE COVERED)
09:00	أ. أحمد الغامدي	CISO و CTO	الإيجاز الصباحي المبدئي واستعراض خطة فحص الضوابط التقنية والمادية

10:00	م. عمر الصالح	إدارة المرافق والأمن المادي	ضوابط الملحق A.7 (الضوابط المادية والبيئية: مركز البيانات بالرياض، الحراسة، ومفاتيح الوصول)
11:00	أ. مريم السديري	إدارة الشبكات والأنظمة	ضوابط الملحق A.8 (الضوابط التقنية: تشفير BitLocker، عزل الشبكات، وضوابط النسخ 3-1-2)
12:00	م. عمر الصالح	فريق SOC والتحقيق الجنائي	ضوابط الملحق A.8.15 (A.8.17 التسجيل، التزامنة التوقيت NTP، وA.8.20 أمن الشبكات)
13:00	فريق التدقيق	—	استراحة الغداء والصلاة
14:00	أ. أحمد الغامدي	CISO وفريق الحوكمة	البند 9 (تقييم الأداء: 9.1 المراقبة والقياس والتحليل، 9.3 مراجعة الإدارة العليا)
15:00	أ. مريم السديري	إدارة المخاطر والامتثال	البند 10 (التحسين: 10.1 التحسين المستمر، و10.2 عدم المطابقة والإجراءات التصحيحية (CAPA)
16:00	فريق التدقيق الداخلي	مغلق (فريق التدقيق فقط)	مداولة فريق التدقيق وتصنيف النتائج وإعداد مسودة تقرير التدقيق الختامي
17:00	أ. أحمد الغامدي	الإدارة التنفيذية وCISO وCTO	الاجتماع الختامي واستعراض النتائج والتوصيات المرفوعة للجنة التدقيق والمخاطر

مرجع: الجدول 4: خطة التدقيق لليوم الثاني (Table 4: Next visit plan - day two)